

Aula 1 (Módulo 12) — IOC, IOA, TTP e o Ecossistema de Threat Intelligence

1. O que é Threat Intelligence (visão simples)

Até aqui, toda investigação partiu de dados **locais** — o que aconteceu na sua própria rede/host. **Threat Intelligence (TI)** é conhecimento **coletado e compartilhado sobre ameaças** que já foram observadas em outros lugares — outras empresas, pesquisadores, governos — e que ajuda você a reconhecer mais rápido algo que já aconteceu com alguém antes de acontecer (ou logo depois de acontecer) com você.

2. IOC — Indicator of Compromise

Um **IOC** é uma "evidência concreta e específica" de que algo malicioso aconteceu ou está acontecendo — os mesmos tipos de dado que já extraímos manualmente no Módulo 06 (`ioc-extractor`): IPs, domínios, hashes, e-mails, URLs.

IOC: hash SHA256 f443bff8...cb5 é conhecido como o ransomware LockBit

IOC: o domínio atualizacao-sistema-seguro.xyz é infraestrutura de C2 conhecida

Característica central dos IOCs: são **específicos e efêmeros** — um atacante troca de IP, gera um novo hash (recompilando o malware) ou registra um novo domínio com facilidade. Um IOC "queimado" (já conhecido/bloqueado) perde valor rapidamente.

3. IOA — Indicator of Attack

Um **IOA** foca no **comportamento**, não em um dado específico — "o que o atacante está tentando fazer", independente de qual arquivo ou IP exato ele está usando dessa vez.

IOA: um processo Office criando um interpretador de comandos como filho

IOA: enumeração de contas de domínio logo após um logon incomum

Por que IOA é mais resistente: um atacante pode trocar de hash e IP facilmente, mas **mudar de técnica** (o comportamento em si) é muito mais difícil e custoso — o atacante teria que reescrever completamente sua ferramenta/abordagem.

4. A Pirâmide da Dor (Pyramid of Pain) — por que essa distinção importa

Um modelo muito citado na comunidade de Blue Team (criado por David Bianco, um pesquisador de segurança — mencionado aqui como referência **comunitária**, não oficial de nenhuma organização) organiza os tipos de indicador por **quanto trabalho custa ao atacante** quando você detecta/bloqueia cada tipo:

TTPs	← "dói muito" (o atacante precisa
Ferramentas	mudar sua abordagem inteira)
Artefatos de Rede	
Artefatos do Host	
Hashes	
Endereços IP	← "dói pouco" (o atacante troca em segundos)

Detectar só por **hash/IP** (base da pirâmide) é fácil de implementar, mas o atacante contorna rapidamente. Detectar por **TTP** (Táticas, Técnicas e Procedimentos — o topo da pirâmide, que vamos formalizar com o MITRE ATT&CK no Módulo 13) é mais difícil de construir, mas força o atacante a um retrabalho muito mais caro para contornar. **IOC ≈ base da pirâmide; IOA/TTP ≈ topo da pirâmide.**

Conclusão prática: um programa de detecção maduro usa **os dois** — IOCs para bloqueio rápido de ameaças já conhecidas (barato e imediato), e IOA/TTP para detectar comportamento malicioso mesmo quando o atacante usa infraestrutura totalmente nova.

5. TTP — Táticas, Técnicas e Procedimentos

- **Tática:** o objetivo geral (ex.: "Persistência", "Movimento Lateral" — vamos ver a lista completa e oficial no Módulo 13).
- **Técnica:** o método específico para alcançar aquele objetivo (ex.: "Registry Run Keys" para persistência).
- **Procedimento:** a implementação **exata** que um grupo específico usa daquela técnica (ex.: o grupo X sempre nomeia a chave de Registry como "WindowsUpdateHelper", como no Cenário 4 do Módulo 10).

6. Threat Actor, Campanha e Malware Family

- **Threat Actor:** uma pessoa, grupo ou organização por trás de ataques — pode ser identificado (com graus variados de confiança) por padrões de TTP consistentes ao longo do tempo. Grupos costumam receber nomes/códigos de diferentes empresas de segurança (frequentemente nomes diferentes para o **mesmo** grupo, dependendo de quem o rastreia — outra razão para tratar atribuição com cautela crítica).
- **Campanha:** um conjunto de atividades de ataque relacionadas, com objetivo/período específico (ex.: uma campanha de phishing direcionada a um setor específico durante um trimestre).
- **Malware family:** uma "linhagem" de malware que evolui ao longo do tempo, mesmo mudando de hash constantemente (ex.: variantes de um mesmo ransomware).

7. Reputação e Enriquecimento

Já vimos **enriquecimento** no Módulo 09, Aula 1 — Threat Intelligence é justamente uma das fontes mais usadas para isso: consultar se um IP/domínio/hash já tem **reputação ruim** conhecida, através de feeds de TI (comerciais ou gratuitos/comunitários), automaticamente adicionando esse contexto a cada evento que passa pelo SIEM.

8. Conectando tudo

IOC (hash, IP, domínio) → específico, efêmero, fácil de trocar (base da pirâmide)
IOA/TTP (comportamento) → difícil de mudar, mais resistente (topo da pirâmide)
Threat Actor/Campanha/Malware Family → o "quem" e "quando" por trás dos IOCs/TTPs

Enriquecimento (Módulo 09) usa Threat Intel para dar CONTEXTO a qualquer IP/hash/domínio que apareça numa investigação

9. Exercício de reflexão

Retome o Cenário 1 do Módulo 10 (PowerShell suspeito filho do Outlook, com `-enc`, conectando a um IP externo):

1. Quais elementos desse cenário são **IOCs**? (Liste especificamente.)
2. Quais elementos são **IOAs/TTPs**? (Liste especificamente.)
3. Se, um mês depois, o mesmo grupo atacar usando um hash e IP totalmente diferentes, mas o **mesmo padrão de comportamento** (Office → PowerShell oculto e ofuscado), qual tipo de detecção (IOC ou IOA) ainda pegaria esse novo ataque?

10. Recapitulando

- IOC = evidência específica (hash, IP, domínio) — fácil de trocar, base da Pirâmide da Dor.
- IOA/TTP = comportamento (o que o atacante está fazendo) — caro de mudar, topo da pirâmide, mais resistente.
- Threat Actor, campanha e malware family dão contexto de **quem** e **quando**; atribuição deve ser tratada com cautela.
- Enriquecimento (Módulo 09) usa Threat Intel para dar contexto automático a qualquer indicador que apareça numa investigação.

Próxima aula (fecha o Módulo 12)

Como analisar, na prática, um IP, domínio, URL, hash ou arquivo suspeito — as ferramentas e o raciocínio usados no dia a dia de Threat Intelligence.

Fontes recomendadas

- **David Bianco — "The Pyramid of Pain"** (recusosecurity.blogspot.com, referência comunitária amplamente citada na indústria, incluindo por fabricantes de segurança em seus próprios materiais oficiais): <https://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html>
- **MITRE ATT&CK — "Groups"**: catálogo oficial de threat actors rastreados publicamente, com TTPs associadas. <https://attack.mitre.org/groups/>
- **NIST SP 800-150 — "Guide to Cyber Threat Information Sharing"**: referência oficial sobre conceitos e boas práticas de compartilhamento de Threat Intelligence. <https://csrc.nist.gov/pubs/sp/800/150/final>